

TỔNG CỤC II
HỌC VIỆN KHOA HỌC QUÂN SỰ

ĐỀ CƯƠNG SƠ BỘ VỀ SÁNG KIẾN
BỘ CÔNG CỤ BẢO ĐẢM AN TOÀN THÔNG TIN VÀ QUYỀN RIÊNG
TƯ DỮ LIỆU ĐA NỀN TẢNG (SECUREVAULT)

Hà Nội, năm 2026

MỤC LỤC

Nhấn chuột phải vào đây rồi chọn “Cập nhật trường” để hiện mục lục.

DANH MỤC CHỮ VIẾT TẮT

Chữ viết tắt	Tiếng Anh	Nghĩa tiếng Việt
ATTT	—	An toàn thông tin
HVKHQs	—	Học viện Khoa học Quân sự
KGM	—	Không gian mạng
AEAD	Authenticated Encryption with Associated Data	Mã hoá có xác thực dữ liệu kèm theo
APK	Android Package	Tệp cài đặt ứng dụng Android
ARM64	64-bit Advanced RISC Machine	Kiến trúc bộ xử lý 64 bit của thiết bị di động
CI	Continuous Integration	Tích hợp liên tục
DLP	Data Loss Prevention	Chống thất thoát dữ liệu
EXIF	Exchangeable Image File Format	Chuẩn siêu dữ liệu trong tệp ảnh
GPS	Global Positioning System	Hệ thống định vị toàn cầu
IPC	Inter-Process Communication	Giao tiếp giữa các tiến trình; ở đây là giữa giao diện và lõi nghiệp vụ
KDF	Key Derivation Function	Hàm dẫn xuất khoá
LSB	Least Significant Bit	Bit ít quan trọng nhất của điểm ảnh
MDM	Mobile Device Management	Quản lý thiết bị di động tập trung
OWASP	Open Worldwide Application Security Project	Tổ chức công bố khuyến nghị về an toàn ứng dụng
QR	Quick Response code	Mã vạch hai chiều
RFC	Request for Comments	Văn bản đặc tả kỹ thuật của IETF
SAF	Storage Access Framework	Cơ chế truy cập bộ nhớ thiết bị có kiểm soát của Android

MỞ ĐẦU

1. Tính cấp thiết của đề tài

Bảo vệ dữ liệu bằng biện pháp mật mã là một nội dung cốt lõi trong chương trình đào tạo an toàn thông tin và bảo đảm an toàn tình báo trên không gian mạng. Tuy nhiên, cách tiếp cận nội dung này hiện nay chủ yếu dừng ở lý thuyết, thuật toán và các công cụ chạy trên máy tính, trong khi thiết bị di động mới là môi trường phổ biến nhất để lưu trữ, trao đổi và xử lý dữ liệu — cũng là môi trường mà học viên sẽ phải bảo vệ dữ liệu nhiều nhất sau khi ra trường. Khoảng cách đó làm giảm hiệu quả huấn luyện: học viên nắm được nguyên lý nhưng chưa từng thao tác, chưa từng quan sát một hệ thống an toàn hoàn chỉnh vận hành ra sao và vì sao nó được thiết kế như vậy.

Song song với nhu cầu huấn luyện, thực tiễn công tác còn đặt ra một nhu cầu thứ hai. Trong những tình huống bất khả kháng, khi một số tài liệu đặc thù buộc phải chuyển gắp qua không gian mạng và không còn phương án chuyển giao nào khác kịp thời hạn, tệp dữ liệu rời khỏi tầm kiểm soát của người gửi và đi qua hạ tầng không do đơn vị quản lý. Đây là tình huống có mức rủi ro cao nhất trong toàn bộ vòng đời của dữ liệu. Người sử dụng cần một công cụ tin cậy, kiểm chứng được để chủ động bổ sung lớp bảo vệ cho tệp trước khi truyền, thay vì phó thác hoàn toàn cho kênh truyền.

Các nhóm giải pháp hiện có đều không đáp ứng trọn vẹn hai nhu cầu trên: mã hoá toàn thiết bị chỉ bảo vệ khi máy chưa mở khoá và không đi theo tệp; ứng dụng “kết riêng tư” trên kho ứng dụng phần lớn mã nguồn đóng nên không kiểm chứng được; công cụ mật mã dòng lệnh có thuật toán tin cậy nhưng lại không có bản dùng được trên thiết bị di động. Nguyên nhân của điểm cuối cùng mang tính kỹ thuật và đáng chú ý hơn cả: các công cụ đó được phân phối dưới dạng tệp nhị phân chạy độc lập, mà hệ điều hành di động không cho ứng dụng sinh tiến trình con để chạy chúng [8]. Đây là rào cản thuộc về kiến trúc nền tảng, không phải vấn đề công sức lập trình, và nó lý giải vì sao khoảng trống nêu trên tồn tại dai dẳng. Chương 1 phân tích cả hai điểm này ở mục 2.4 và 2.5.

Bên cạnh khía cạnh kỹ thuật, yêu cầu tuân thủ quy định cũng đặt ra ranh giới rõ ràng cho đề tài. Việc quản lý, lưu trữ và chuyển giao tài liệu mật, tài liệu nội bộ tại Học viện Khoa học Quân sự và các cơ quan, đơn vị có yêu cầu cao về bảo vệ thông tin phải tuân thủ nghiêm ngặt các quy định hiện hành [1], [2], [3]; đơn vị không cho phép đưa tài liệu mật và tài liệu nội bộ lên thiết bị di động cá nhân. Ranh giới này được xác định ngay từ đầu và giữ nguyên trong suốt quá trình thực hiện, thay vì để phát lộ khi sản phẩm đã hoàn thành.

Xuất phát từ những yêu cầu trên, đề tài “*Bộ công cụ bảo đảm an toàn thông tin và quyền riêng tư dữ liệu đa nền tảng (SecureVault)*” nghiên cứu và xây dựng một bộ công cụ bảo vệ dữ liệu hoạt động hoàn toàn trên thiết bị, dùng chung một lõi nghiệp vụ

và một định dạng dữ liệu cho nhiều nền tảng, trong đó bản dành cho thiết bị di động là trọng tâm vì đó chính là nơi rào cản kỹ thuật tồn tại và cần được giải quyết.

2. Mục tiêu nghiên cứu

Đề tài hướng tới xây dựng một bộ công cụ bảo đảm an toàn thông tin và quyền riêng tư dữ liệu, hoạt động hoàn toàn trên thiết bị của người dùng, không phụ thuộc máy chủ hay dịch vụ trực tuyến, đủ tin cậy để dùng trong công tác và đủ trực quan để dùng làm học cụ trong giảng dạy an toàn thông tin, bảo đảm an toàn tình báo trên không gian mạng.

Về mặt kỹ thuật, mục tiêu đặt ra là thiết kế một kiến trúc trong đó toàn bộ nghiệp vụ bảo vệ dữ liệu — định dạng tệp, sơ đồ khoá, quy tắc xử lý lỗi và các phép mật mã — nằm trong một lõi độc lập với giao diện và với nền tảng; những thành phần buộc phải phụ thuộc nền tảng được tách ra sau các điểm nối trừu tượng đặt đúng chỗ. Nhờ đó, chuyển sang một môi trường triển khai khác không còn là viết lại sản phẩm mà chỉ là thay phần nằm trên các điểm nối ấy, trong khi nghiệp vụ, định dạng dữ liệu và cơ chế bảo vệ giữ nguyên.

Trên cơ sở kiến trúc đó, đề tài xây dựng hai bản triển khai dùng chung một lõi: bản cho thiết bị di động Android — trọng tâm của đề tài, nơi phải giải quyết rào cản tiến trình con của hệ điều hành — và bản cho máy tính để bàn, giữ vai trò đối chứng và mở rộng phạm vi sử dụng. Mục tiêu bao trùm là mọi kết quả đều kiểm chứng được: mỗi tuyên bố kỹ thuật phải gắn với một cách kiểm tra bằng máy, và những phần chưa kiểm chứng phải được nêu rõ thay vì bỏ qua.

3. Nhiệm vụ nghiên cứu

- Nghiên cứu cơ sở lý luận về bảo vệ dữ liệu ở trạng thái lưu trữ và trạng thái truyền, các nguyên hàm mật mã tương ứng, cơ chế dẫn xuất khoá từ mật khẩu, chia sẻ bí mật theo ngưỡng và các kênh lộ thông tin nằm ngoài nội dung tệp.
- Nghiên cứu cơ sở lý luận về kiến trúc phần mềm độc lập nền tảng và kỹ thuật đặt điểm nối trừu tượng tại ranh giới phụ thuộc nền tảng.
- Khảo sát các nhóm giải pháp bảo vệ dữ liệu hiện có, phân tích ưu điểm và những nhược điểm chưa được khắc phục, xác định chính xác khoảng trống cần lấp.
- Phân tích rào cản kỹ thuật của nền tảng di động đối với các công cụ mật mã được phân phối dưới dạng tệp nhị phân chạy độc lập, và xác định hướng khắc phục bằng thiết kế.
- Thiết kế định dạng tệp dữ liệu, sơ đồ phân cấp khoá và quy tắc phân loại lỗi theo hướng không làm lộ thông tin qua thông báo lỗi.
- Xây dựng lõi nghiệp vụ và các nhóm chức năng bảo vệ dữ liệu; triển khai trên nền tảng di động và nền tảng máy tính để bàn từ cùng một lõi.

- Thiết kế giao diện theo hướng coi giao diện là một thành phần của thiết kế an toàn, hạn chế sai sót thao tác có thể dẫn tới lộ dữ liệu.
- Tổ chức kiểm chứng nhiều mức: kiểm thử tự động, kiểm thử trên đúng kiến trúc bộ xử lý của thiết bị di động, đối chứng tương thích định dạng với công cụ chuẩn độc lập, kiểm tra tĩnh gói cài đặt và xây dựng quy trình nghiệm thu trên thiết bị thật.

4. Đối tượng nghiên cứu

- Các cơ chế bảo vệ dữ liệu bằng mật mã: mã hoá có xác thực, chữ ký số, hàm băm mật mã, dẫn xuất khoá từ mật khẩu và chia sẻ bí mật theo ngưỡng.
- Các kênh lộ thông tin nằm ngoài nội dung tệp: siêu dữ liệu trong tệp ảnh, dữ liệu ẩn trong ảnh và dấu hiệu chỉnh sửa ảnh.
- Kiến trúc phần mềm cho phép tách nghiệp vụ khỏi giao diện và khỏi nền tảng, cùng cơ chế lựa chọn bản hiện thực theo nền tảng tại thời điểm biên dịch.
- Ràng buộc của hệ điều hành di động đối với việc thực thi mã và truy cập bộ nhớ thiết bị.
- Phương pháp kiểm chứng phần mềm an toàn: kiểm thử tự động, kiểm thử theo kiến trúc bộ xử lý, đối chứng tương thích định dạng và kiểm tra tĩnh gói cài đặt.

5. Phạm vi nghiên cứu

Đề tài tập trung xây dựng bộ công cụ bảo vệ dữ liệu hoạt động ngoại tuyến trên thiết bị của người dùng, phục vụ hai kịch bản sử dụng: huấn luyện học viên về an toàn thông tin, bảo mật dữ liệu; và hỗ trợ cán bộ bổ sung lớp bảo vệ cho tệp trong tình huống khẩn cấp, bất khả kháng buộc phải chuyển giao qua không gian mạng và đã được cấp có thẩm quyền cho phép. Nền tảng trọng tâm là thiết bị di động Android; bản trên máy tính để bàn được xây dựng từ cùng một lõi, giữ vai trò đối chứng và mở rộng phạm vi sử dụng.

Đề tài không tự xây dựng thuật toán mật mã mới. Các nguyên hàm được sử dụng đều là chuẩn đã công bố, đã được cộng đồng nghiên cứu và đánh giá lâu dài [11]–[16]; phần đóng góp nằm ở việc lựa chọn nguyên hàm nào cho việc gì, ghép chúng lại trong một kiến trúc thống nhất và đặt tham số phù hợp với ràng buộc tài nguyên của thiết bị di động.

Đề tài cũng không đề xuất thay đổi hay nói lỏng bất kỳ quy định nào về bảo vệ bí mật. Việc một tài liệu cụ thể có được phép lưu trữ, xử lý hay chuyển giao qua một phương thức nhất định hay không vẫn hoàn toàn do quy định hiện hành và người có thẩm quyền quyết định [1], [3]; sản phẩm chỉ bổ sung biện pháp kỹ thuật nhằm giảm rủi ro trong phạm vi những hoạt động đã được phép thực hiện. Ngoài phạm vi đề tài còn có: bảo vệ dữ liệu khi thiết bị đã bị chiếm quyền điều khiển ở mức hệ điều hành, và việc đóng gói bản cài đặt có ký số, công chứng phục vụ phân phối rộng rãi.

6. Phương pháp nghiên cứu

- *Phương pháp nghiên cứu lý thuyết*: phân tích, tổng hợp và hệ thống hoá tài liệu về mật mã ứng dụng, đặc tả các nguyên hàm và định dạng dữ liệu mở, khuyến nghị tham số của các tổ chức chuyên môn, cùng tài liệu kỹ thuật của nền tảng di động.
- *Phương pháp phân tích và thiết kế hệ thống*: khảo sát yêu cầu, xác lập mô hình mối đe dọa, xác định các nguyên lý thiết kế, phân rã hệ thống thành những thành phần có quan hệ phụ thuộc một chiều và thiết kế định dạng dữ liệu.
- *Phương pháp thực nghiệm*: xây dựng sản phẩm, chạy bộ kiểm thử tự động, chạy lỗi trên đúng kiến trúc bộ xử lý của thiết bị di động, đối chứng tệp dữ liệu với công cụ chuẩn do bên thứ ba phát triển và kiểm tra tình gói cài đặt đã đóng gói.
- *Phương pháp đánh giá*: đối chiếu từng chỉ tiêu đặt ra với kết quả đo được và với nguồn sinh ra kết quả đó, phân biệt rõ giữa chức năng đã hiện thực và chức năng đã được kiểm chứng bằng thực nghiệm.

7. Đóng góp của đề tài

Về lý luận. Đề tài hệ thống hoá cơ sở lý luận về bảo vệ dữ liệu theo tệp trên thiết bị của người dùng và làm rõ một vấn đề kiến trúc ít được bàn tới: vì sao các công cụ mật mã tin cậy trên máy tính không chuyển thẳng được sang thiết bị di động, và có thể khắc phục bằng thiết kế như thế nào. Đề tài cũng đề xuất cách chuyển hoá các nguyên lý thiết kế an toàn thành những ràng buộc kỹ thuật kiểm tra được bằng máy, thay vì để chúng dừng ở mức khuyến nghị trong tài liệu.

Về thực tiễn. Đề tài tạo ra một sản phẩm hoàn chỉnh, dùng được trong công tác huấn luyện và trong tình huống chuyển giao đặc thù, với toàn bộ mã nguồn và bộ kiểm thử do đơn vị làm chủ. Mỗi nhóm chức năng của sản phẩm gắn với một nguyên lý có sẵn trong chương trình đào tạo, nên sản phẩm đồng thời là học cụ trực quan cho phép học viên thao tác, quan sát kết quả và hiểu cả giới hạn của từng biện pháp bảo vệ.

8. Kết cấu của đề cương

Ngoài phần Mở đầu, Kết luận và Tài liệu tham khảo, đề cương gồm hai chương: *Chương 1 — Cơ sở khoa học và thực tiễn của đề tài*; *Chương 2 — Xây dựng bộ công cụ SecureVault*.

Đề cương này là một trong các văn bản của bộ hồ sơ sáng kiến lập theo mẫu của đơn vị [5]. Phần trình bày cô đọng dành cho hội đồng nằm ở văn bản Thuyết minh [6]; phần diễn giải kỹ thuật đầy đủ, mô tả từng chức năng kèm giao diện và toàn bộ bằng chứng kiểm chứng nằm ở Đề cương chi tiết [7].

CHƯƠNG 1. CƠ SỞ KHOA HỌC VÀ THỰC TIỄN CỦA ĐỀ TÀI

1. Cơ sở lý luận

1.1. Hai trạng thái của dữ liệu và ba cách tiếp cận bảo vệ

Trong an toàn thông tin, dữ liệu được xem xét ở hai trạng thái với hai loại rủi ro khác nhau. Ở trạng thái lưu trữ, dữ liệu nằm trên thiết bị và rủi ro đến từ việc thiết bị bị mất, bị mượn hoặc tệp bị sao chép ra ngoài. Ở trạng thái truyền, dữ liệu đi qua hạ tầng mà người gửi không kiểm soát, rủi ro đến từ việc bị chặn bắt, sửa đổi hoặc giả mạo nguồn gốc.

Điểm cần phân biệt là các biện pháp phổ biến hiện nay chỉ phủ được một trong hai trạng thái. Mã hoá toàn thiết bị bảo vệ dữ liệu ở trạng thái lưu trữ, nhưng chỉ khi máy chưa mở khoá, và bảo vệ đó chấm dứt ngay khi tệp rời thiết bị. Mã hoá đầu-cuối của các ứng dụng nhắn tin bảo vệ rất tốt ở trạng thái truyền nhưng không bảo vệ tệp đã lưu trên máy. Cách tiếp cận thứ ba — bảo vệ theo tệp — gắn lớp bảo vệ vào chính tệp dữ liệu, nhờ đó phủ được cả hai trạng thái: tệp mang theo cơ chế tự bảo vệ, nên dù nằm trên máy hay đang trên đường truyền thì vẫn cần đúng bí mật mới mở được. Đây là cách tiếp cận mà đề tài lựa chọn, và nó chi phối toàn bộ các quyết định thiết kế về sau.

1.2. Các nguyên hàm mật mã và vai trò của từng loại

Một hệ thống bảo vệ dữ liệu hoàn chỉnh cần nhiều loại nguyên hàm mật mã, mỗi loại giải quyết một vấn đề riêng và không thay thế được cho nhau. Mã hoá có xác thực vừa giữ bí mật nội dung vừa phát hiện mọi thay đổi trên bản mã; đây là cải tiến quan trọng so với mã hoá thuần túy, vốn giấu được nội dung nhưng không cho biết bản mã đã bị can thiệp hay chưa [12], [13]. Hàm băm mật mã tạo ra một giá trị đại diện ngắn cho tệp, dùng để đối chiếu hai bản sao mà không phải so từng byte [16]. Chữ ký số dựa trên mật mã khoá công khai cho phép bên nhận tự xác minh nguồn gốc và tính toàn vẹn của tệp mà không cần tin vào kênh truyền [14].

1.3. Dẫn xuất khoá từ mật khẩu và bài toán chống dò

Mật khẩu do người dùng đặt có entropy thấp hơn nhiều so với một khoá mật mã. Nếu dùng mật khẩu trực tiếp làm khoá, kẻ tấn công có được tệp mã hoá chỉ cần thử lần lượt các mật khẩu khả dĩ. Hàm dẫn xuất khoá từ mật khẩu được thiết kế để làm cho mỗi lần thử trở nên tốn kém: bên cạnh chi phí thời gian, các hàm hiện đại còn yêu cầu một lượng bộ nhớ đáng kể cho mỗi phép tính [11].

Tham số bộ nhớ quan trọng hơn số vòng lặp, vì đó là thứ vô hiệu hoá lợi thế của phần cứng chuyên dụng dò mật khẩu hàng loạt — loại phần cứng có thể nhân số phép tính lên hàng nghìn lần nhưng không nhân được dung lượng bộ nhớ theo cùng tỷ lệ. Bài toán đặt ra cho đề tài là chọn ngưỡng đủ cao để có ý nghĩa chống dò, nhưng vẫn để

một điện thoại phổ thông mở được tệp trong thời gian người dùng chấp nhận được; khuyến nghị tối thiểu của tổ chức chuyên môn [17] được lấy làm căn cứ.

1.4. Chia sẻ bí mật theo ngưỡng

Nguyên tắc không lưu mật khẩu lâu dài mang lại an toàn nhưng kéo theo một hệ quả: quên mật khẩu đồng nghĩa mất dữ liệu vĩnh viễn. Cách xử lý thông thường — giao khoá dự phòng cho một bên thứ ba giữ hộ — lại tạo ra đúng thứ mà thiết kế đang cố tránh: một điểm mà chỉ cần xâm phạm là lấy được toàn bộ.

Chia sẻ bí mật theo ngưỡng giải quyết vấn đề này bằng cách chia một bí mật thành n mảnh sao cho bất kỳ k mảnh nào cũng khôi phục được, còn $k-1$ mảnh thì không tiết lộ gì về bí mật gốc — không phải “khó đoán hơn” mà là *không mang thông tin* nào theo nghĩa lý thuyết thông tin [15]. Tính chất này cho phép tách quyền kiểm soát: các mảnh được giao cho những người hoặc nơi cất giữ khác nhau, và không ai trong số đó một mình khôi phục được dữ liệu. Đây cũng là một nguyên lý có sẵn trong chương trình đào tạo, nên chức năng tương ứng có giá trị kép: vừa dùng thật, vừa minh hoạ được trên lớp.

1.5. Các kênh lộ thông tin nằm ngoài nội dung tệp

Bảo vệ nội dung tệp là điều kiện cần nhưng chưa đủ. Một tệp ảnh chụp bằng điện thoại thường mang theo khối siêu dữ liệu chứa toạ độ định vị, kiểu thiết bị, thời điểm chụp và nhiều thông tin khác [18]. Những dữ liệu này đi kèm tệp mà người dùng không nhận biết, tạo thành một kênh lộ thông tin nằm hoàn toàn ngoài nội dung — và trong nhiều tình huống, toạ độ nơi chụp còn nhạy cảm hơn bản thân bức ảnh.

Hai kỹ thuật liên quan cũng thuộc phạm vi nghiên cứu. *Giấu tin trong ảnh* nhúng dữ liệu vào các bit ít quan trọng của điểm ảnh — không phải biện pháp thay thế mã hoá mà chỉ là một lớp bổ sung, vì che giấu không đồng nghĩa với không thể bị phát hiện. *Thủy vân dễ vỡ* nhúng một dấu hiệu vô hình gắn với mật khẩu, sao cho mọi chỉnh sửa ảnh đều phá vỡ dấu hiệu đó; khác với chữ ký số vốn chỉ cho biết tệp còn nguyên vẹn hay không, thủy vân còn hỗ trợ khoanh vùng vị trí bị can thiệp.

1.6. Kiến trúc phần mềm độc lập với giao diện và nền tảng

Cơ sở lý luận cuối cùng thuộc về kỹ nghệ phần mềm, và chính là chỗ đề tài đặt đóng góp của mình. Nguyên tắc nền tảng là *đảo ngược chiều phụ thuộc*: thay vì để phần nghiệp vụ gọi trực tiếp một công cụ cụ thể, phần nghiệp vụ chỉ phụ thuộc vào một giao diện trừu tượng mô tả *việc cần làm*, còn *cách làm* được cung cấp từ bên ngoài vào tại thời điểm lắp ráp chương trình [10].

Điểm khó nằm ở chỗ đặt ranh giới trừu tượng đó ở đâu. Đặt quá cao — ở mức nghiệp vụ — thì mỗi nền tảng phải viết lại toàn bộ nghiệp vụ và hai bản sẽ trôi xa nhau theo thời gian. Đặt quá thấp — ở mức từng phép mật mã — thì mỗi bản hiện thực phải tự ghép lại đúng định dạng tệp và rất dễ lệch. Ranh giới hợp lý là nơi mô tả được bằng

một hợp đồng dữ liệu chặt chẽ: một luồng vào, một luồng ra theo một định dạng công khai. Khi đó hai bản hiện thực khác nhau hoàn toàn về cách chạy vẫn buộc phải sinh ra cùng một chuỗi byte — điều kiểm chứng được bằng thực nghiệm, không phải bằng lập luận.

2. Cơ sở thực tiễn

2.1. Đặc điểm môi trường công tác và ranh giới của đề tài

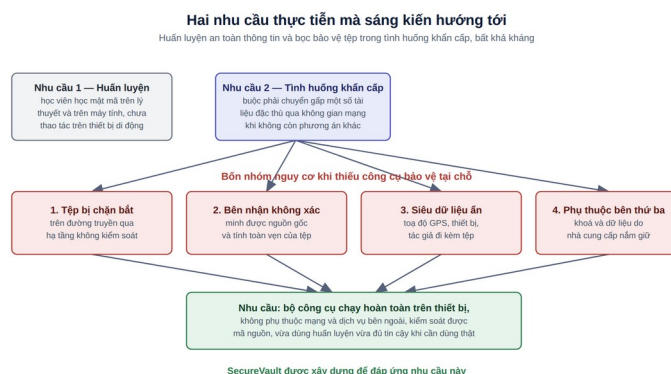
Môi trường công tác tại Học viện Khoa học Quân sự đặt ra yêu cầu nghiêm ngặt về quản lý, lưu trữ và chuyển giao tài liệu mật, tài liệu nội bộ. Đặc biệt, đơn vị không cho phép đưa tài liệu mật và tài liệu nội bộ lên thiết bị di động cá nhân. Đây là điểm xuất phát của đề tài chứ không phải một hạn chế phát sinh về sau: nó loại bỏ ngay một hướng đi tưởng như hiển nhiên — xây dựng ứng dụng để mang tài liệu công tác theo người — và buộc đề tài phải tìm giá trị ở hai nhu cầu khác, trình bày ở hai mục tiếp theo.

2.2. Nhu cầu phục vụ huấn luyện an toàn thông tin

Nội dung mật mã ứng dụng trong chương trình đào tạo hiện được giảng chủ yếu qua lý thuyết và qua công cụ chạy trên máy tính. Học viên nắm được thuật toán nhưng ít khi quan sát được một hệ thống an toàn hoàn chỉnh hoạt động, và gần như không có cơ hội thao tác trên đúng loại thiết bị mà họ sẽ dùng nhiều nhất sau khi ra trường. Điều cần có là một môi trường thực hành an toàn, nơi học viên trực tiếp mã hoá tệp bằng mật khẩu, tạo và kiểm tra chữ ký số, chia khoá theo ngưỡng, xoá siêu dữ liệu và kiểm tra toàn vẹn — với kết quả quan sát được ngay. Quan trọng không kém, học viên phải thấy được *giới hạn* của mỗi biện pháp: hiểu sai về giới hạn của một công cụ an toàn còn nguy hiểm hơn không dùng công cụ nào, vì nó tạo ra cảm giác an toàn không có thật.

2.3. Nhu cầu bảo vệ tệp trong tình huống chuyển giao khẩn cấp

Trong công tác vẫn phát sinh tình huống một số tài liệu đặc thù buộc phải chuyển gấp qua không gian mạng khi không còn phương án nào khác kịp thời hạn. Với những trường hợp đã được cấp có thẩm quyền cho phép chuyển giao, cán bộ cần một công cụ để chủ động tăng cường lớp bảo vệ trước khi truyền. Bốn cơ chế tương ứng với bốn nhóm nguy cơ: mã hoá bằng mật khẩu để nội dung không đọc được khi tệp bị tiếp cận trái phép; ký số để bên nhận tự xác minh nguồn gốc và tính toàn vẹn; xoá siêu dữ liệu để không vô tình gửi kèm toạ độ định vị và thông tin thiết bị; chia bí mật theo ngưỡng để một kênh bị lộ vẫn chưa đủ khôi phục dữ liệu. Mục tiêu rất cụ thể: nếu tệp bị chặn bắt trên đường truyền thì bên chặn bắt thu được bản mã, không phải nội dung.



Hình 1. Hai nhu cầu thực tiễn mà đề tài hướng tới và bốn nhóm nguy cơ tương ứng

2.4. Khảo sát các nhóm giải pháp hiện có và khoảng trống

Sáu nhóm giải pháp đã được khảo sát trước khi quyết định tự xây dựng. Nhận xét rút ra không phải là các giải pháp hiện có kém — mỗi nhóm đều làm tốt việc mà nó được thiết kế cho — mà là chúng được thiết kế cho những bài toán khác.

Bảng 1. Khoảng trống của từng nhóm giải pháp so với nhu cầu đặt ra

Nhóm giải pháp	Điểm chưa đáp ứng được
Mã hoá toàn thiết bị của hệ điều hành	Chỉ bảo vệ khi máy tắt hoặc chưa mở khoá lần đầu; khi máy đã mở khoá thì mọi ứng dụng đều thấy dữ liệu ở dạng rõ, và tệp rời thiết bị thì không còn được bảo vệ
Ứng dụng “khoá tệp”, “kết riêng tư” trên kho ứng dụng	Phần lớn mã nguồn đóng nên không kiểm chứng được thuật toán và cách quản lý khoá; nhiều ứng dụng đòi quyền mạng; định dạng riêng khoá người dùng vào một sản phẩm
Trình quản lý mật khẩu mã nguồn mở	Thiết kế cho thông tin đăng nhập, không nhằm xử lý tệp, ảnh, tài liệu; không có ký số, kiểm tra toàn vẹn, chia khoá phục hồi hay xử lý siêu dữ liệu
Công cụ mật mã dòng lệnh	Thuật toán tin cậy nhưng không có bản dùng được trên thiết bị di động, vì lý do trình bày ở mục 2.5; giao diện dòng lệnh không phù hợp người dùng không chuyên
Ứng dụng nhắn tin mã hoá đầu-cuối	Bảo vệ đường truyền nhưng không bảo vệ dữ liệu ở trạng thái lưu trên máy; dữ liệu vẫn đi qua hạ tầng của nhà cung cấp dịch vụ nước ngoài
Giải pháp quản lý thiết bị / chống thất thoát dữ liệu (MDM/DLP)	Cần hạ tầng máy chủ, chi phí bản quyền và phụ thuộc nhà cung cấp; khó triển khai cho nhu cầu cá nhân và nhóm nhỏ

Hai nhu cầu ở mục 2.2 và 2.3 đòi hỏi đồng thời bốn tính chất: bảo vệ theo tệp chứ không theo thiết bị; kiểm chứng được chứ không phải tin vào nhà cung cấp; chạy được trên thiết bị di động; và đủ nhiều nghiệp vụ để dùng làm học cụ. Không nhóm nào có đủ cả bốn. Đó chính là khoảng trống mà đề tài hướng tới.

2.5. Rào cản kỹ thuật của nền tảng di động

Câu hỏi tự nhiên là: nếu đã có công cụ mã dòng lệnh tin cậy, vì sao không đưa thẳng chúng lên điện thoại? Câu trả lời nằm ở cách hệ điều hành di động kiểm soát việc thực thi mã. Các công cụ đó được phân phối dưới dạng tệp nhị phân chạy độc lập, và trên máy tính để bàn, ứng dụng gọi chúng như một tiến trình con. Trên thiết bị di động, cơ chế này bị chặn ở hai tầng khác nhau: iOS cấm hoàn toàn việc một ứng dụng sinh tiến trình; Android cho phép sinh tiến trình nhưng chặn thực thi tệp nhị phân nằm trong vùng lưu trữ mà ứng dụng ghi được — tức đúng nơi mà một tệp nhị phân đóng gói kèm ứng dụng sẽ nằm [8].

Điều khiến rào cản này đáng chú ý về mặt phương pháp là *nó không lộ ra ở giai đoạn biên dịch*. Mã nguồn dựng thành công, ứng dụng cài được, mở được, và chỉ hỏng khi người dùng bấm vào chức năng. Vì vậy nó phải được xử lý bằng thiết kế kiến trúc ngay từ đầu, không phải bằng việc sửa lỗi về sau — và đó là căn cứ cho toàn bộ cách tiếp cận trình bày ở Chương 2.

2.6. Căn cứ pháp lý và yêu cầu bảo đảm an toàn thông tin

Đề tài được thực hiện trong khuôn khổ các quy định hiện hành về an toàn thông tin và bảo vệ bí mật nhà nước. Luật An toàn thông tin mạng [1] và Luật An ninh mạng [2] đặt ra yêu cầu chung về bảo vệ thông tin trên không gian mạng; Luật Bảo vệ bí mật nhà nước [3] quy định chế độ quản lý đối với tài liệu thuộc danh mục bí mật nhà nước; Nghị định về công tác văn thư [4] quy định thể thức và kỹ thuật trình bày văn bản, cũng là căn cứ cho cách trình bày bộ hồ sơ này.

Hai hệ quả được giữ xuyên suốt. *Thứ nhất*, đề tài không đưa ra tuyên bố nào về việc sản phẩm được phép xử lý tài liệu thuộc danh mục bí mật nhà nước ở một cấp độ cụ thể; việc đó thuộc thẩm quyền của cơ quan có trách nhiệm. *Thứ hai*, sản phẩm được thiết kế theo hướng thu hẹp bề mặt rủi ro: hoạt động hoàn toàn trên thiết bị, không có thành phần máy chủ, không khai báo quyền truy cập mạng — nên về mặt kỹ thuật không tồn tại đường dữ liệu đi ra khỏi thiết bị do chính ứng dụng tạo ra.

Kết luận chương 1

Chương 1 đã xác lập cơ sở của đề tài trên ba mặt. *Về lý luận*, bảo vệ dữ liệu hiệu quả đòi hỏi cách tiếp cận theo tệp thay vì theo thiết bị, cần nhiều loại nguyên hàm mật mã bổ trợ nhau, và phải tính đến cả những kênh lộ thông tin nằm ngoài nội dung tệp. *Về kỹ nghệ phần mềm*, tách nghiệp vụ khỏi giao diện và khỏi nền tảng bằng các điểm nối trừu tượng đặt đúng chỗ là điều kiện để một lõi dùng chung cho nhiều môi trường triển khai. *Về thực tiễn*, hai nhu cầu huấn luyện và chuyển giao khẩn cấp tồn tại trong ranh giới quy định cho phép, trong khi các giải pháp sẵn có để lại một khoảng trống mà nguyên nhân là rào cản kiến trúc của nền tảng di động. Đây là căn cứ trực tiếp cho Chương 2.

CHƯƠNG 2. XÂY DỰNG BỘ CÔNG CỤ SECUREVAULT

Chương này trình bày định hướng thực hiện theo từng nhóm công việc: nội dung sẽ làm, căn cứ lựa chọn và tiêu chí để xác định là đã làm được. Phần diễn giải kỹ thuật ở mức từng cơ chế, bảng mô tả chi tiết chức năng và kịch bản kiểm thử được trình bày trong văn bản 05 — Đề cương chi tiết về sáng kiến [7].

1. Phân tích bài toán và xác định yêu cầu

1.1. Xác lập mô hình mối đe dọa

Nội dung đầu tiên, thực hiện trước khi thiết kế: xác định các giả định nền — hệ điều hành chưa bị chiếm quyền, người dùng giữ được bí mật của mình — cùng danh sách những tình huống sản phẩm phải bảo vệ được và, quan trọng không kém, những tình huống sản phẩm *không* bảo vệ được. Việc công bố giới hạn ngay từ đầu vừa định hướng thiết kế, vừa tránh cho người dùng một cảm giác an toàn không có thật.

1.2. Xác lập các nguyên lý thiết kế

Sáu nguyên lý được chốt trước khi viết dòng mã đầu tiên: hoạt động ngoại tuyến tuyệt đối; một lỗi bảo vệ dữ liệu dùng chung; phụ thuộc một chiều theo lớp; khi không bảo đảm an toàn thì không tiếp tục xử lý; thông báo lỗi không làm lộ thông tin bí mật; không lưu trữ bí mật lâu dài. Yêu cầu tự đặt ra là mỗi nguyên lý phải chuyển hoá được thành một ràng buộc kiểm tra được bằng máy — nguyên lý chỉ nằm trong tài liệu thì sớm muộn cũng bị vi phạm khi phần mềm được sửa đổi về sau.

1.3. Yêu cầu chức năng và yêu cầu phi chức năng

Yêu cầu chức năng được xác định theo nhóm nghiệp vụ: bảo vệ nhiều tệp dưới một mật khẩu; bảo vệ tệp đơn lẻ; kiểm chứng nguồn gốc và toàn vẹn; sao lưu và khôi phục theo ngưỡng; xử lý các kênh lộ thông tin ngoài nội dung. Yêu cầu phi chức năng gồm: không yêu cầu quyền truy cập mạng, không tài khoản, không đồng bộ đám mây; tệp đầu ra theo chuẩn mở để không khoá người dùng vào một sản phẩm; mã nguồn kiểm soát được kèm bộ kiểm thử để bên thứ ba chạy lại và tự kết luận.

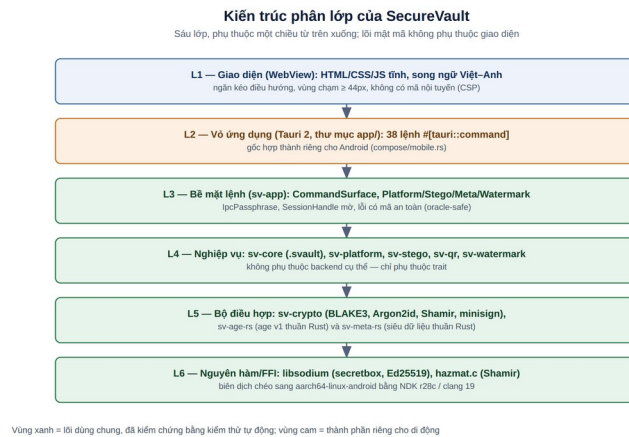
1.4. Đối tượng sử dụng và kịch bản thao tác

Ba nhóm đối tượng với ba cách dùng khác nhau: giảng viên dùng sản phẩm làm học cụ trên lớp; học viên thực hành và tự bảo vệ dữ liệu cá nhân để hình thành thói quen nghề nghiệp; cán bộ dùng trong tình huống chuyển giao đặc thù đã được cho phép. Mỗi nhóm ứng với một tập kịch bản thao tác riêng, là căn cứ để thiết kế luồng giao diện ở mục 6.

2. Thiết kế kiến trúc hệ thống

2.1. Phân lớp hệ thống và chiều phụ thuộc

Tổ chức hệ thống thành các lớp với quan hệ phụ thuộc một chiều, trong đó giao diện tách hẳn khỏi lõi nghiệp vụ và mọi yêu cầu từ giao diện xuống lõi đều đi qua một tập lệnh được kiểm soát thống nhất, không có đường truy cập trực tiếp nào khác. Lõi được phân rã thành các thành phần độc lập, mỗi thành phần một trách nhiệm; việc phân rã không nhằm cho “gọn” mà để chiều phụ thuộc giữa các thành phần trở thành thứ kiểm tra được bằng máy chứ không phải bằng đọc lại tài liệu.



Hình 2. Kiến trúc phân lớp dự kiến của SecureVault

2.2. Xác định vị trí các điểm nối trừu tượng

Đây là quyết định kiến trúc quan trọng nhất của đề tài. Cần xác định chính xác những thành phần buộc phải phụ thuộc nền tảng, đặt điểm nối ngay tại đó và chỉ tại đó, rồi mô tả điểm nối bằng một hợp đồng dữ liệu chặt đến mức hai bản hiện thực khác nhau vẫn phải cho ra cùng một kết quả. Căn cứ để chọn vị trí đã phân tích ở mục 1.6 Chương 1.

2.3. Mô hình phiên làm việc và vòng đời của bí mật

Thiết kế sao cho bí mật không đi qua ranh giới giữa lõi và giao diện nhiều lần: giao diện chỉ nhận một mã phiên ngẫu nhiên không mang thông tin, còn khoá nằm trong bộ nhớ của lõi và bị xoá dứt khoát khi người dùng kết thúc phiên. Mật khẩu khi truyền qua các lớp được quản lý bằng kiểu dữ liệu tự xoá nội dung khi hết phạm vi sử dụng.

3. Thiết kế định dạng dữ liệu và cơ chế bảo vệ

3.1. Cấu trúc tệp dữ liệu được bảo vệ

Thiết kế cấu trúc tệp với ba yêu cầu bắt buộc: danh mục các tệp bên trong phải nằm trong phần đã mã hoá, để tệp đang khoá không tiết lộ cả tên lẫn số lượng tệp; khoá chỉ được lưu ở dạng đã bọc, không bao giờ ở dạng rõ; và chữ ký phải phủ lên cả

phần đầu lẫn phần nội dung để không thể ghép phần đầu của tệp này với nội dung của tệp khác. Định dạng phải được coi là đóng băng sau khi chốt, vì mọi thay đổi về sau đều làm hỏng những tệp đã tạo trước đó.

3.2. Sơ đồ phân cấp khoá

Thiết kế đường đi từ mật khẩu tới các khoá con: dẫn xuất khoá chính bằng hàm dẫn xuất có tham số bộ nhớ theo ngưỡng khuyến nghị [17], rồi từ khoá chính sinh các khoá con gắn với ngữ cảnh riêng cho từng mục đích và từng tệp. Mục tiêu là đạt hai tính chất kiểm tra được: khoá của một mục đích không dùng được cho mục đích khác, và khối dữ liệu đã bọc không mang được từ tệp này sang tệp khác.

3.3. Lựa chọn nguyên hàm và tham số

Chọn nguyên hàm cho từng vai trò trong thiết kế — dẫn xuất khoá, băm và sinh khoá con, mã hoá nội dung, bảo vệ trường khoá, ký số, chia khoá phục hồi — trên cơ sở đặc tả công khai và mức độ được cộng đồng soi xét [11]–[16], [19]. Tham số đặt theo khuyến nghị của tổ chức chuyên môn, có cân nhắc ràng buộc tài nguyên của thiết bị di động.

3.4. Quy tắc phân loại lỗi an toàn

Xây dựng quy tắc chiếu lỗi từ lỗi ra giao diện: lỗi phân biệt nguyên nhân lỗi ở mức chi tiết để gỡ lỗi được, nhưng khi vượt qua ranh giới thì các nguyên nhân được gộp về một tập hẹp theo quy tắc cố định, sao cho chênh lệch giữa các thông báo không trở thành tín hiệu dò mật khẩu. Quy tắc phải áp dụng thống nhất cho mọi bản hiện thực — nếu hai nền tảng báo lỗi khác nhau trong cùng một tình huống thì chính sự khác nhau đó lại thành kênh rò rỉ mới.

4. Xây dựng các nhóm chức năng nghiệp vụ

4.1. Bảo vệ dữ liệu ở trạng thái lưu trữ

Xây dựng cơ chế kết an toàn — một tệp chứa nhiều tệp dưới một mật khẩu — và cơ chế bảo vệ tệp đơn lẻ cho những trường hợp không cần lập kết. Kèm theo là các thao tác vòng đời đầy đủ: tạo, mở, khoá, đổi mật khẩu, thêm và trích xuất tệp, xem thông tin. Yêu cầu về an toàn dữ liệu: mọi thao tác ghi phải theo kiểu nguyên tử, để một lần ghi bị gián đoạn không biến tệp cũ thành tệp hỏng.

4.2. Kiểm chứng nguồn gốc và tính toàn vẹn

Xây dựng chức năng tạo cặp khoá ký, ký tệp, kiểm tra chữ ký, lấy vân tay tệp và đối chiếu tệp với vân tay cho trước. Nguyên tắc trình bày: những chức năng dùng chung nền tảng kỹ thuật nhưng phục vụ mục đích khác nhau thì tách riêng, tránh buộc người dùng tự suy luận xem nên chọn chức năng nào.

4.3. Sao lưu và khôi phục theo ngưỡng

Xây dựng chức năng chia một bí mật hoặc một tệp thành nhiều mảnh với ngưỡng khôi phục do người dùng đặt, khôi phục từ đủ số mảnh, và chuyển mảnh sang thiết bị khác bằng mã QR. Giao diện phải diễn đạt ngưỡng bằng lời thay cho ký hiệu toán học, và khi chưa đủ mảnh thì báo rõ còn thiếu bao nhiêu.

4.4. Xử lý các kênh lộ thông tin ngoài nội dung

Xây dựng chức năng xem, xoá và so sánh siêu dữ liệu của tệp; giấu dữ liệu đã mã hoá vào ảnh và phát hiện dấu hiệu dữ liệu ẩn; nhúng và kiểm tra thủy vân dễ vỡ. Với nhóm này, yêu cầu bắt buộc là công bố đúng phạm vi xử lý thực tế và từ chối rõ ràng khi gặp dữ liệu ngoài phạm vi, thay vì báo thành công cho một việc chưa chắc đã làm được. Chức năng so sánh siêu dữ liệu tồn tại để người dùng *tự kiểm tra* kết quả, không phải chỉ tin vào thông báo của ứng dụng.

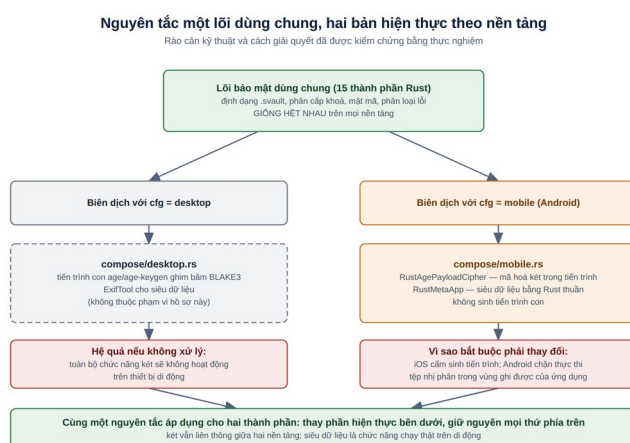
5. Triển khai trên hai nền tảng từ cùng một lỗi

5.1. Bản trên máy tính để bàn

Xây dựng trước, giữ vai trò bản đối chứng và bản tham chiếu ngữ nghĩa: khi bản di động cho kết quả khác, bản này là chuẩn để đối chiếu. Ở nền tảng này, các thành phần phụ thuộc nền tảng được hiện thực bằng cách điều khiển công cụ chuẩn dưới dạng tiến trình con, có kiểm tra tính toàn vẹn của tệp nhị phân được gọi.

5.2. Bản trên thiết bị di động — trọng tâm của đề tài

Đây là nơi rào cản ở mục 2.5 Chương 1 phát sinh và phải được giải quyết. Nội dung công việc gồm: hiện thực mô-đun mã hoá nội dung chạy ngay trong tiến trình ứng dụng nhưng giữ nguyên định dạng tệp đã thiết kế; tự xây dựng mô-đun xử lý siêu dữ liệu thay cho công cụ ngoài không dùng được trên nền tảng này; và xử lý luồng tệp theo cơ chế truy cập bộ nhớ có kiểm soát của Android [9], sao cho lỗi nghiệp vụ không phải thay đổi giao diện dữ liệu của nó.



Hình 3. Nguyên tắc một lỗi dùng chung, hai bản hiện thực theo nền tảng

5.3. Bảo toàn tính nhất quán giữa hai nền tảng

Đặt ra một ràng buộc bắt buộc: dù thay bản hiện thực nào bên dưới, định dạng tệp trên đĩa không được thay đổi. Đây là loại ràng buộc dễ bị vi phạm âm thầm và không phát hiện được bằng cách đọc mã, nên phải kiểm chứng bằng thực nghiệm — nội dung ở mục 7.

6. Thiết kế giao diện người dùng

6.1. Giao diện như một thành phần của thiết kế an toàn

Với một ứng dụng bảo vệ dữ liệu, một thao tác sai vì giao diện gây hiểu nhầm cũng dẫn tới lộ dữ liệu như một lỗi mật mã. Bốn nguyên tắc được đặt ra: trình bày theo công việc cần làm chứ không theo thuật toán; phân tầng thông tin để người dùng mới không bị ngợp mà người muốn kiểm chứng vẫn đủ dữ kiện; cảnh báo liên quan tới nguy cơ mất dữ liệu thì không được thu gọn; và không để kết quả của thao tác trước bị hiểu nhầm là kết quả của thao tác mới.

6.2. Thích ứng cho màn hình cảm ứng

Dùng chung mã giao diện cho cả hai nền tảng và chỉ điều chỉnh bố cục theo nền tảng đang chạy, thay vì duy trì hai giao diện độc lập — cách này bảo đảm hai bản không lệch nhau về nội dung theo thời gian. Yêu cầu kiểm tra kèm theo: việc bổ sung bố cục cho màn hình nhỏ không được làm thay đổi kết quả hiển thị của bản trên máy tính.

6.3. Đối chiếu chức năng với giao diện

Yêu cầu tự đặt ra là mọi chức năng của lõi đều phải có giao diện thao tác tương ứng, và ngược lại mọi lệnh mà giao diện gọi đều phải tồn tại trong lõi. Việc đối chiếu thực hiện trực tiếp trên mã nguồn theo hai chiều: chiều thứ nhất phát hiện chức năng đã làm nhưng người dùng không với tới được, chiều thứ hai phát hiện nút bấm gọi tới lệnh không tồn tại.

7. Kiểm chứng và đánh giá

Nguyên tắc chung cho toàn bộ phần này: mỗi tuyên bố kỹ thuật phải gắn với một cách kiểm tra bằng máy, và phải phân biệt rõ giữa *đã hiện thực* với *đã kiểm chứng bằng thực nghiệm*. Bảng dưới trình bày các mức kiểm chứng dự kiến cùng kết quả đạt được tại thời điểm lập hồ sơ.

Bảng 2. Các mức kiểm chứng dự kiến và kết quả đạt được

Mức kiểm chứng	Cách làm	Kết quả
7.1. Kiểm thử tự động	Bộ kiểm thử chạy trên máy chủ tích hợp liên tục	263 đạt / 0 lỗi trên tổng số 272 hàm
7.2. Đúng kiến trúc bộ xử lý của thiết bị di động	Chạy lõi dưới trình giả lập kiến trúc ARM64, trên mã đã	146 đạt / 0 lỗi

	biên dịch cho kiến trúc đó	
7.3. Tương thích định dạng giữa hai nền tảng	Đối chứng hai chiều với công cụ chuẩn độc lập; mở chéo tệp giữa hai bản hiện thực	5 phép đối chứng đều đạt
7.4. Đa nền tảng	Dựng, soát mã và chạy kiểm thử trên ma trận hệ điều hành máy tính (Windows, macOS, Linux)	9 hạng mục đạt, biên bản 2026-06-15
7.5. Kiểm tra tình gói cài đặt	Mở gói cài đặt sẽ giao cho người dùng và đọc nội dung bên trong	Đúng kiến trúc thư viện; không khai báo quyền mạng
7.6. Nghiệm thu trên thiết bị thật	Quy trình 15 bước, mỗi bước có thao tác và tiêu chí đạt cụ thể	Chưa thực hiện — quy trình đã soạn

Trong sáu mức trên, mức 7.3 đáng nói riêng vì nó kiểm chứng đúng tuyên bố trung tâm của kiến trúc. Phép đối chứng dùng *công cụ chuẩn do bên thứ ba viết*: khi tệp do sản phẩm tạo ra được công cụ đó đọc đúng và ngược lại, kết luận về tính tương thích không còn phụ thuộc vào lời khẳng định của nhóm tác giả.

8. Nhận xét về khối lượng công việc và kết quả

Sản phẩm dự kiến và kết quả thực tế. Bộ công cụ gồm 38 chức năng nghiệp vụ thao tác qua 21 màn hình giao diện, xây dựng trên 15 thành phần mã nguồn dùng chung cho mọi nền tảng, kèm 272 hàm kiểm thử tự động. Bản dành cho thiết bị di động đã được đóng gói thành tệp cài đặt Android hoàn chỉnh (42,3 MB); bản trên máy tính dùng đúng lõi đó và đã dựng, chạy kiểm thử đạt trên Windows, macOS, Linux. Toàn bộ quá trình thực hiện diễn ra trong khoảng từ 2026-06-15 đến 2026-09-10, ghi nhận qua lịch sử kho mã nguồn [20].

Một điều chỉnh so với dự kiến ban đầu. Nhóm chức năng xử lý siêu dữ liệu ban đầu dự kiến dùng lại cách làm của bản trên máy tính. Khi triển khai lên nền tảng di động mới phát hiện cách đó vướng đúng rào cản đã phân tích ở mục 2.5 Chương 1, nên phải bổ sung một khối công việc không có trong kế hoạch: tự xây dựng mô-đun xử lý siêu dữ liệu. Trường hợp này minh họa rõ đặc điểm của rào cản đang bàn — nó chỉ lộ ra khi chạy thật, không lộ ra ở giai đoạn biên dịch.

Kết luận chương 2

Chương 2 đã trình bày định hướng thực hiện theo tám nhóm công việc, từ phân tích yêu cầu, thiết kế kiến trúc và định dạng dữ liệu, xây dựng các nhóm chức năng, triển khai trên hai nền tảng, thiết kế giao diện cho tới tổ chức kiểm chứng và đánh giá. Mạch công việc bám theo một tuyến duy nhất: đặt toàn bộ nghiệp vụ vào một lõi độc lập nền tảng, giải quyết rào cản của nền tảng di động tại đúng điểm nối đã thiết kế, rồi chứng minh bằng thực nghiệm rằng hai bản hiện thực cho ra cùng một định dạng dữ

liệu. Kết quả và bằng chứng chi tiết của từng nhóm công việc được trình bày trong văn bản 05 [7].

KẾT LUẬN

1. Kết quả đạt được

Đề tài đã xác lập được cơ sở khoa học cho một cách tiếp cận bảo vệ dữ liệu theo tệp trên thiết bị của người dùng, và làm rõ nguyên nhân kiến trúc khiến các công cụ mật mã tin cậy trên máy tính không chuyển thẳng được sang thiết bị di động. Trên cơ sở đó, đề tài xây dựng được một bộ công cụ hoàn chỉnh với 38 chức năng nghiệp vụ, dùng chung một lõi gồm 15 thành phần cho cả nền tảng di động lẫn nền tảng máy tính, trong đó bản di động — trọng tâm của đề tài — đã đóng gói thành tệp cài đặt hoàn chỉnh. Tính nhất quán của kiến trúc được chứng minh bằng thực nghiệm: tệp dữ liệu tạo bằng bản hiện thực của nền tảng này mở được bằng bản của nền tảng kia, và tệp do sản phẩm tạo ra đọc được bằng công cụ chuẩn do bên thứ ba phát triển.

2. Hạn chế

Tại thời điểm lập hồ sơ, việc nghiệm thu trên thiết bị Android thật chưa được thực hiện; mọi kiểm chứng đều tiến hành trên máy chủ, kể cả phép chạy dưới trình giả lập kiến trúc. Bên cạnh đó, bản cài đặt có ký số và công chứng cho nền tảng máy tính chưa được đóng gói, nên đề tài không tuyên bố sản phẩm đã sẵn sàng phân phối rộng rãi trên các hệ điều hành máy tính. Phạm vi định dạng của mô-đun xử lý siêu dữ liệu trên nền tảng di động hẹp hơn bản trên máy tính; giới hạn này được công bố trực tiếp trên giao diện thay vì che đi. Cuối cùng, sản phẩm không bảo vệ được dữ liệu khi thiết bị đã bị chiếm quyền điều khiển ở mức hệ điều hành — giới hạn thuộc về bản chất của mọi biện pháp ở mức ứng dụng.

3. Hướng phát triển

Thứ tự ưu tiên tiếp theo: thực hiện quy trình nghiệm thu trên nhiều dòng thiết bị và phiên bản hệ điều hành khác nhau; hoàn thiện khâu đóng gói có ký số cho bản trên máy tính; nghiên cứu sử dụng kho khoá phần cứng của thiết bị cho một số khoá nằm ngoài hệ thống khoá của tệp dữ liệu, kèm tùy chọn xác thực sinh trắc; mở rộng phạm vi định dạng của mô-đun siêu dữ liệu; và biên soạn bộ bài giảng, phiếu bài thực hành đi kèm để đưa sản phẩm vào chương trình huấn luyện chính thức.

TÀI LIỆU THAM KHẢO

- [1] Quốc hội, Luật An toàn thông tin mạng, số 86/2015/QH13, Hà Nội, 2015.
- [2] Quốc hội, Luật An ninh mạng, số 24/2018/QH14, Hà Nội, 2018.
- [3] Quốc hội, Luật Bảo vệ bí mật nhà nước, số 29/2018/QH14, Hà Nội, 2018.

- [4] Chính phủ, Nghị định số 30/2020/NĐ-CP về công tác văn thư, Hà Nội, 2020.
- [5] Học viện Khoa học Quân sự, Mẫu hồ sơ sáng kiến cải tiến kỹ thuật, Công văn số 324/HVKHQ-S-PKHQS, Hà Nội, 2026.
- [6] Nhóm tác giả đề tài, Thuyết minh sáng kiến — văn bản 02 của bộ hồ sơ, Hà Nội, 2026.
- [7] Nhóm tác giả đề tài, Đề cương chi tiết về sáng kiến — văn bản 05 của bộ hồ sơ, Hà Nội, 2026.
- [8] Android Developers, Application Sandbox và ràng buộc thực thi mã trên vùng lưu trữ của ứng dụng, tài liệu kỹ thuật nền tảng Android, 2026.
- [9] Android Developers, Storage Access Framework và Scoped Storage, tài liệu kỹ thuật nền tảng Android, 2026.
- [10] R. C. Martin, “The Dependency Inversion Principle”, C++ Report, 1996.
- [11] IETF, RFC 9106 — Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications, 2021.
- [12] IETF, RFC 8439 — ChaCha20 and Poly1305 for IETF Protocols, 2018.
- [13] IETF, RFC 7748 — Elliptic Curves for Security, 2016.
- [14] IETF, RFC 8032 — Edwards-Curve Digital Signature Algorithm (EdDSA), 2017.
- [15] A. Shamir, “How to share a secret”, Communications of the ACM, vol. 22, no. 11, pp. 612–613, 1979.
- [16] J. O’Connor, J.-P. Aumasson, S. Neves, Z. Wilcox-O’Hearn, BLAKE3: One Function, Fast Everywhere — đặc tả hàm băm và cơ chế dẫn xuất khoá theo ngữ cảnh, 2020.
- [17] OWASP Foundation, Password Storage Cheat Sheet — khuyến nghị tham số tối thiểu cho Argon2id (19 MiB bộ nhớ, 2 vòng lặp), OWASP Cheat Sheet Series, truy cập năm 2026.
- [18] CIPA, Exchangeable image file format for digital still cameras: Exif Version 2.32, tiêu chuẩn CIPA DC-008, 2019.
- [19] F. Valsorda và cộng sự, The age encryption format — đặc tả định dạng tệp mã hoá mở, phiên bản 1, truy cập năm 2026.
- [20] Nhóm tác giả đề tài, SecureVault: mã nguồn, bộ kiểm thử tự động và tài liệu kiểm chứng, kho mã nguồn của đề tài, ghi nhận ngày 2026-09-10.

Hà Nội, ngày 09 tháng 9 năm 2026

XÁC NHẬN CỦA ĐƠN VỊ

CHỦ NHIỆM SÁNG KIẾN

Thượng úy Trần Thị Tới